

Lab 03: Social Engineering

Cybersecurity F26

March 18th, 2026

Sani Abdullahi

1. Introduction

In this lab, you will learn to identify social engineering attacks, including phishing, vishing, and smishing. You will also perform controlled phishing simulations using the Social Engineering Toolkit (SET) and GoPhish. SET and GoPhish are open-source tools designed for security testing and awareness training. They allow security professionals and IT teams to design, execute, and monitor phishing campaigns in a safe and controlled environment. The primary objective is to understand how social engineering attacks are carried out and to develop effective strategies for detecting and defending against them.

Lab Exercises: Part 1 – Social Engineering

Exercise 1: Urgent Password Reset Scenario

You are an employee working in the finance department of a mid-sized company. It's a busy morning, and you're focused on your tasks. Suddenly, you receive an urgent phone call from someone claiming to be from the IT support team.

- The caller introduces himself as "John from IT Support" and mentions that they have been working on some updates to your department's network security.
- John says there's an issue with your account that needs immediate resolution, and to fix it, you must reset your password immediately to prevent a potential security breach. He mentions that this is part of a "company-wide" security upgrade.
- He offers to help you reset your password right away.
- The caller is very friendly and speaks confidently, and he claims that if you don't act quickly, you could lose access to important financial documents.

Tasks

1. Do you trust the call? Why or why not?
2. Should you click the link in the email or go directly to your company's official portal?
3. What steps should you take to verify the legitimacy of the request?

4. How would you handle the situation if you were unsure whether this was a legitimate IT request or a phishing attempt?
5. What action should you take if you suspect the call may be an attempt at social engineering?

Exercise 2: Urgent Payroll Verification Scenario

SDU employees receive an SMS on their personal phones during the workday. The message appears to come from the SDU's HR department. SDU HR recently migrated to a new payroll platform.

The SMS Message:

SDU HR:

We detected an issue with your payroll details after the system upgrade.

Please confirm your information before 16:00 today to avoid salary delays.

Verify here: <http://hr-payroll-secure.sdu/verify>

If already completed, please ignore.

Tasks

1. What could make the message believable?
2. What red flags could you detect from the message?
3. What should an employee do instead of clicking the link?
4. How could the organization reduce the success rate of this attack?

Exercise 3: Company Portal Login Scenario

Alice is on a business trip. She needs to log in to the company web portal to download the sensitive documents she needs for her work during the trip. She sees a free WiFi hotspot in her hotel but is reluctant to connect because she is not sure whether communications with her company portal will be secured.

Tasks

1. What factors could make Alice hesitant to connect to the hotel's free WiFi?
2. If Alice decides to connect to WiFi, what steps should be taken before connecting?
3. What security risks are associated with accessing sensitive company documents over public WiFi?

4. How might an attacker exploit an unsecured or fake hotspot in this situation?
5. What security measures could the company implement to protect employees accessing systems while traveling?

Exercise 4: Important Deadline Scenario

Bob receives an email from his coworker, Alice, asking him to share a sensitive document with her. She is on vacation, so she does not have access to her work device. She mentions an important deadline for submitting a report for which she requires the document. She is anxious that she will not be able to meet this deadline unless she works on the report before she comes back to the office.

Tasks

1. What should Bob do in this case?
2. What aspects of Alice's request could make Bob feel pressured to share the document?
3. What social engineering techniques might be used in this message?
4. What risks are involved in sharing sensitive documents through email in this situation?
5. How could Bob verify that the request actually came from Alice?
6. What company policies or procedures should Bob follow before sharing the document?

Lab Exercises: Part 2 – Phishing Simulation

Introduction

In this lab, you will explore two widely used phishing simulation tools, SET and GoPhish, to conduct controlled phishing exercises. The guides for using these tools are already provided in the preparatory materials. Therefore, the lab activities will primarily focus on designing and simulating phishing campaigns.

Exercise 5: Social Engineering Toolkit (SET)

In this exercise, you will simulate a phishing attack using SET.

Tasks

1. Open the terminal in your kali machine and launch the SET.

2. Create a Phishing Email:

- Choose a target group (e.g., fellow students or employees). **I suggest that you form groups based on the ones you created in Itslearning for exercise submission. For example, students in Group 1 (Social Engineers) can target students in Group 2 (Defenders), and vice versa.**
- Use SET's Email Attack feature to craft a phishing email. The email should contain:
 - A malicious link that redirects the target to a fake login page or a page that requests sensitive information (e.g., username, password, credit card).
 - A sense of urgency or fear (e.g., "Your account has been compromised! Please reset your password immediately!").
 - Personalization (e.g., use the target's name, company name, or reference something specific to make the email appear authentic).

3. Create a Fake Website:

- Using SET's Website Attack feature, create a fake login page for a well-known site (e.g., Gmail, Facebook, or an internal company portal).
- The page should look as legitimate as possible (matching colors, logos, fonts, and layout).

4. Launch the Phishing Campaign:

- Send the phishing email to the target group and direct them to the fake login page you created.
- Track whether the target clicks the link and enters any sensitive information.

5. Report and Analysis:

- Once the attack is complete, analyze whether your target provided any information (e.g., login credentials).

6. Defence:

- What characteristics of SET-generated phishing emails or cloned websites can help users identify them?
- How can security tools detect and block credential harvesting pages created with SET?
- What configurations (e.g., email security, domain monitoring) can prevent SET-based phishing campaigns from reaching users?

Exercise 6: GoPhish

In this exercise, you will use GoPhish to simulate a phishing attack.

Tasks

1. Launch GoPhish from your Kali machine
2. Configure SMTP settings for sending phishing emails.
3. Create a landing page (e.g., fake login page).
4. Create Target Group: Maintain the same groups used in Exercise 5.
5. Design Email: Write a phishing email with a malicious link (e.g., "Urgent: Account Verification").
6. Include a fake login page link.
7. Create Fake Landing Page: Mimic a legitimate website with a login form to capture credentials.
8. Launch Campaign: Send phishing emails to the target group.
9. Track Interactions: Monitor email open rates, click rates, and credential captures via GoPhish's dashboard.
10. Review Campaign Data: Examine open rates, clicks, and credential submissions.
11. Defence: Use the same questions (Exercise 5, Task 6) for defending against phishing attacks in the SET and adapt them for use with GoPhish.

NOTE: I'll suggest that you use dummy emails or fake profiles for the phishing campaign
